

מודול 1 — תרגול ותרchiשים

חומר לימוד

1 יחידות

תוכן העניינים

1.  תרגול — מודול 1: מבוא ומתודולוגיה

תרגול — מודול 1: מבוא ומתודולוגיה

חלק א' — שאלות תרגול (עם תשובות). חלק ב' — תרחיש מהחיים האמיתיים. נסה לבד לפני שתקרא את התשובות.

חלק א' — שאלות תרגול

- Q1. מהו הסדר הנכון של חמשת שלבי ההאקינג האתי?
- Q2. מהם שלושת עקרונות ה-CIA Triad? תן דוגמה לפגיעה בכל אחד.
- Q3. מה ההבדל בין בדיקת White Box, Grey Box, Black Box?
- Q4. הסבר את הנוסחה $Vulnerability + Exploit + Payload = גישה$ בעזרת דוגמת "הדלת".
- Q5. אילו מסמכים משפטיים נדרשים לפני בדיקת חדירות, ומה תפקיד כל אחד?
- Q6. מהו ההבדל בין תוקף White Hat ל-Grey Hat?
- Q7. למה מצב רשת Bridged מסוכן במעבדה, ומה עדיף להשתמש?
- Q8. לאיזה שלב שייכת כל פעולה: (א) `nmap -sV` (ב) חיפוש עובד ב-LinkedIn (ג) מחיקת לוגים (ד) הוספת משתמש לחזרה מאוחרת?

תשובות

1. Recon → Scanning → Gaining Access → Maintaining Access → Covering Tracks.
2. Confidentiality (דלף סיסמאות), Integrity (שינוי סכום העברה), Availability (מתקפת DoS).
3. Black = מידע מינימלי (תוקף חיצוני); White = גישה מלאה (קוד+פרטים); Grey = מידע חלקי (הנפוץ).
4. Vulnerability = מנעול פגום, Exploit = שיטת הפריצה, Payload = מה שעושים בפנים.
5. Scope (מה מותר), RoE (כללי התקשרות), NDA (סודיות), מכתב הרשאה (הוכחת חוקיות).
6. White Hat פועל בהרשאה מלאה; Grey Hat ללא הרשאה אך לרוב ללא זדון (עדיין לא חוקי).
7. Bridged נותן ל-VM כתובת ברשת האמיתית → סכנת פגיעה ברשת הביתית. עדיף NAT/Host-Only.
8. (א) Scanning (ב) Recon (ג) Covering Tracks (ד) Maintaining Access.

חלק ב' — תרחיש מהחיים האמיתיים

📞 “היום הראשון בבדיקה”

חברת סטארטאפ קטנה שכרה אותך לבדיקת חדירות **External Black Box**. קיבלת חוזה, NDA, ומסמך Scope שבו כתוב: In-Scope: *.startup.co.il · כל, Out-of-Scope: mail.startup.co.il. 'שירות צד ג'.

המשימה שלך — תכנן את היום הראשון. ענה: 1. איזה סוג בדיקה זה, ואיזה פרופיל תוקף אתה מדמה? 2. מה הפעולה הראשונה שלך — ולאיזה שלב מחמשת השלבים היא שייכת? 3. גילית שרת מעניין בכתובת mail.startup.co.il שנראה פגיע. מה מותר לך לעשות איתו? 4. כתוב תוכנית פעולה בת 5 שורות — שורה לכל שלב מתודולוגי.

💡 פתרון מנחה

1. **External Black Box**; פרופיל: תוקף חיצוני ללא פרטי גישה וללא ידע פנימי.
2. **Recon פסיבי** — WHOIS, תת-דומיינים (Sublist3r), OSINT, **לא** קופצים לסריקה. שלב 1.
3. mail.startup.co.il הוא **Out-of-Scope** → **אסור** לגעת בו. מותר לתעד ולדווח ללקוח ולהמליץ להוסיפו לבדיקה נפרדת.
4. תוכנית לדוגמה:
 - Recon: איסוף תת-דומיינים, מיילים, טכנולוגיות (In-Scope בלבד).
 - Scanning: nmap על הנכסים המורשים, מיפוי שירותים.
 - Gaining Access: ניצול החולשה החמורה ביותר שנמצאה.
 - Maintaining Access: שתילת גישה (רק אם ה-RoE מתיר).
 - Covering Tracks / Reporting: ניקוי + תיעוד לדוח.

🎯 שים לב: החלטה **אתית/חוקית** (סעיף 3) חשובה כמו היכולת הטכנית. זה מה שמבדיל מקצוען.

⬅ חזרה למודול · תרגילים מעשיים